

Что вышло из проверки 53 требований — простым языком

Два аудитора смотрели список независимо: Sol и Orus.

Сошлись в главном: почти всё старое не нужно. Sol сказал «не нужно» про 41 требование из 53, Orus — про 35. Причина одна: это либо уже сделано другими работами, либо противоречит вашим сегодняшним решениям, либо машинерия ради машинерии.

Сошлись по отложенному: 12 требований — настоящие, но делать сейчас нечего, потому что нет предусловия. Это библиотека упражнений платформы (ждёт магазина), свои каналы рассылок (строятся в соседней задаче) и система обращений в поддержку (её ещё нет).

Разошлись в одном месте, и это важно. Sol не нашёл ни одного требования, которое надо делать сейчас. Orus нашёл шесть. Спор не про вкус, а про факт: Sol считает, что защита уже стоит, Orus — что она держится на одной строке в коде и не покрыта ни одним тестом. Проверяю третьим прогоном, кто прав по коду.

Шесть спорных — что это значит по-человечески

1. **Клиника А и клиника В могут увидеть чужие упражнения и видео.** Разделение сейчас держится только на проверке внутри приложения. Уровень базы для этих таблиц отключён старой миграцией, а автотестов, что чужое не видно, нет вообще ни одного. Если строчку проверки случайно потеряют при правке — никто не заметит.
2. **Отключение клиники может задеть соседнюю.** Живой прогон планировался на одной клинике. Если пересчёт состояний пойдёт без указания, чью клинику считаем, он либо выключит не тех, либо не выключит никого. Проверять надо на двух клиниках сразу.
3. **Платформенная аналитика отдаёт персональные строки пациентов.** Ручка не различает клиники и по контракту возвращает имена и идентификаторы людей. Единственная защита сейчас — что права на неё никому не выданы. Рядом в репозитории уже есть правильный образец: похожая ручка честно отказывает.

Остальные три — того же класса: места, где защита есть на словах, но не проверена ничем.

Что я с этим делаю

Проверяю шесть спорных по коду третьим прогоном. Добавлю в план только те, где отказ действительно достижим сегодня — с формулировкой на русском и названным сценарием.

Всё про биллинг и оплату теперь идёт в отдельный план по биллингу, как вы велели: план тарифов и квот и план оплаты больше не смешиваются. Стык между ними записан одной строкой — счёт клиники это цена тарифа плюс дополнительные специалисты, а ступень отключения включается от состояния оплаты, но длительности задаёте вы.